CYBERSECURITY PORTFOLIO PROJECT | NIST CSF ALIGNED

Security Audit & Compliance Assessment Report

Target Organization: Botium Toys	**Lead Auditor:** Syed Yasir Shah
Framework: NIST CSF v1.1 | PCI DSS | GDPR | SOC 2	**Audit Status:** Completed (Final Assessment)

1. Executive Summary

Botium Toys is a growing enterprise that manufactures and markets toys through both physical storefronts and a high-traffic e-commerce platform. As part of its international market expansion—most notably to customers in the European Union (EU)—the organization initiated this comprehensive internal security audit. The goal is to evaluate the operating security posture, safeguard critical consumer data, and ensure strict compliance with international statutory standards.

> **Audit Finding:** While Botium Toys maintains solid physical security safeguards and standard perimeter firewall rules, critical deficiencies exist across identity and access management, encryption, system resiliency, and regulatory compliance. Customer cardholder details and personal identifiable information (PII) are currently stored in plain text and accessible by all employees, introducing severe operational, legal, and financial risks.

2. Scope & Audit Goals

Audit Scope:

- • Physical Facilities: Corporate headquarters, customer-facing storefronts, and manufacturing/distribution warehouses.
- • Systems & Infrastructure: Internal corporate network, transaction servers, employee endpoints, and legacy systems.
- • Regulatory Scopes: Compliance alignment under PCI DSS (payment handling), GDPR (EU data privacy), and SOC Type 1 & 2 controls.

Audit Objectives:

- 1. Inventory and assess physical, technical, and administrative controls currently active within Botium Toys.
- 2. Evaluate operational alignment against PCI DSS, GDPR, and SOC 2 compliance mandates.
- 3. Produce structured, risk-prioritized recommendations mapped to the NIST Cybersecurity Framework (CSF) to remediate identified vulnerabilities.

3. Controls Assessment Checklist

Assessment of current administrative, technical, and physical controls against baseline enterprise security standards:

Control	Category	In Place?	Audit Explanation & Risk Analysis
Least Privilege	Identity & Access	**No**	Currently, all employees have access to customer data; privileges need to be limited to reduce the risk of a breach.
Disaster Recovery Plans	System Resiliency	**No**	There are no disaster recovery plans in place. These need to be implemented to ensure business continuity.
Password Policies	Identity & Access	**No**	Employee password requirements are minimal, which could allow a threat actor to more easily access secure data/other assets via work equipment.
Separation of Duties	Identity & Access	**No**	Needs to be implemented to reduce the possibility of fraud/access to critical data, since the company CEO currently runs day-to-day operations and manages payroll.
Firewall	Perimeter Defense	**Yes**	The existing firewall blocks traffic based on an appropriately defined set of security rules.
Intrusion Detection System (IDS)	Network Security	**No**	The IT department needs an IDS in place to help identify possible intrusions by threat actors.
Data Backups	Data Protection	**No**	The IT department needs backups of critical data in the case of a breach or incident to ensure business continuity.
Antivirus Software	Endpoint Defense	**Yes**	Antivirus software is installed and monitored regularly across systems by the IT department.
Legacy Systems Management	System Resiliency	**No**	Legacy systems are monitored and maintained, but lack a regular scheduled routine and standard intervention procedures, increasing breach risks.
Data Encryption	Data Protection	**No**	Encryption is not currently used; implementing it would provide greater confidentiality of sensitive financial and customer data.
Password Management System	Identity & Access	**No**	There is no password management system currently in place; implementing this control would enforce security and improve employee productivity.
Physical Locks	Physical Security	**Yes**	The store's physical location, main offices, storefront, and warehouse facilities have sufficient physical lock mechanisms.
CCTV Surveillance	Physical Security	**Yes**	Operational closed-circuit television (CCTV) cameras are installed and functioning at all physical locations.

Fire Detection / Prevention	Physical Security	**Yes**	Physical premises are equipped with functional fire detection alarms and automated sprinkler suppression systems.

4. Compliance Assessment Checklist

4.1 Payment Card Industry Data Security Standard (PCI DSS)

Compliance Best Practice	Adheres?	Explanation & Finding
Only authorized users have access to customers' credit card information.	**No**	Currently, all employees have open access to internal company databases including customer credit card details.
Credit card information is accepted, processed, transmitted, and stored internally in a secure environment.	**No**	Credit card info is not encrypted; cardholder data touches unsegmented networks accessible to all staff.
Implement data encryption procedures to better secure credit card transaction touchpoints and data.	**No**	The company does not currently use encryption algorithms to ensure the confidentiality of customers' financial records.
Adopt secure password management policies.	**No**	Password requirements are minimal, and no centralized enterprise password management or multi-factor solution is in place.

4.2 General Data Protection Regulation (GDPR)

Compliance Best Practice	Adheres?	Explanation & Finding
E.U. customers' data is kept private and secured.	**No**	The company does not currently implement cryptographic protection to ensure confidentiality of E.U. customer data and financial assets.
Plan in place to notify E.U. customers within 72 hours if their data is compromised/breached.	**Yes**	A formal notification procedure is documented to alert regulatory bodies and affected EU customers within 72 hours of an incident.
Ensure data is properly classified and inventoried.	**No**	Company assets have been inventoried and listed, but have not been formally classified according to data sensitivity levels.
Enforce privacy policies, procedures, and processes to properly document and maintain data.	**Yes**	Privacy policies and handling procedures have been developed and communicated across internal IT personnel and staff.

4.3 System and Organization Controls (SOC Type 1 & SOC Type 2)

Compliance Best Practice	Adheres?	Explanation & Finding
User access policies are established and enforced.	No	Controls for Least Privilege and Separation of Duties are missing; all employees have unvetted access to internally stored data.
Sensitive data (PII / SPII) is confidential and private.	No	Encryption is not currently implemented to safeguard the confidentiality of Personally Identifiable Information.
Data integrity ensures data is consistent, complete, accurate, and validated.	Yes	Basic system data integrity controls and verification checks are functioning.
Data is available to individuals authorized to access it.	No	Data is accessible to all employees rather than strictly limited to authorized roles with valid operational justification.

5. Risk Assessment & Gap Analysis

Based on the assessment findings, Botium Toys exhibits high-exposure vulnerabilities across the Confidentiality and Availability dimensions of the CIA Triad:

- • Critical Risk of Data Exfiltration (Confidentiality): With zero database encryption and unrestricted employee access rights, a single phishing email or endpoint compromise would give an adversary access to complete customer records and payment cards.
- • Regulatory Non-Compliance & Severe Penalties: Operating non-compliant with PCI DSS exposes Botium Toys to processing bans and bank penalties. Non-compliance with GDPR exposes the company to regulatory fines up to €20M or 4% of total worldwide annual turnover.
- • Operational Disruption & Ransomware Susceptibility (Availability): The absence of data backups, disaster recovery plans, and intrusion detection systems leaves the company defenseless against ransomware or database corruption, threatening business continuity.

6. Strategic Recommendations (NIST CSF Roadmap)

To systematically address these vulnerabilities, recommendations are categorized using the core functions of the NIST Cybersecurity Framework (Identify, Protect, Detect, Respond, Recover) across a phased timeline:

Phase 1: Immediate Remediation (Days 1–30) — Protect & Comply

- 1. Implement Role-Based Access Control (RBAC) & Least Privilege [NIST PR.AC-4]: Immediately segment database access. Restrict customer financial records exclusively to billing personnel.
- 2. Deploy Cryptographic Safeguards [NIST PR.DS-1]: Enforce AES-256 bit encryption on databases at rest and TLS 1.3 for all web traffic and API payment processing channels.
- 3. Enforce Separation of Duties [NIST PR.AC-6]: Reassign payroll and core ledger operations away from the CEO to dedicated accounting roles with mandatory dual authorization.

Phase 2: Resiliency & Visibility (Days 30–60) — Identify & Detect

- 4. Deploy an Intrusion Detection System (IDS) [NIST DE.AE-1]: Deploy network-based IDS (e.g., Snort/Suricata) to monitor boundary traffic and detect anomalous lateral movement.
- 5. Automated 3-2-1 Data Backup Strategy [NIST PR.IP-4]: Configure immutable, automated daily backups with off-site cloud replication. Test quarterly restoration drills.
- 6. Enterprise Password Manager & MFA [NIST PR.AC-7]: Mandate enterprise Single Sign-On (SSO) with Multi-Factor Authentication (MFA) across all administrative access points.

Phase 3: Governance & Lifecycle (Days 60–90) — Govern & Recover

- 7. Formal Asset & Data Classification Scheme [NIST ID.AM-5]: Classify all organizational data assets (Public, Internal, Confidential, Restricted) to formalize retention and handling rules.
- 8. Comprehensive Disaster Recovery Plan (DRP) [NIST RC.RP-1]: Document RTO (Recovery Time Objective) and RPO (Recovery Point Objective) targets with tabletop incident simulation tests.
- 9. Legacy Systems Vulnerability & Patch Management [NIST ID.RA-1]: Establish a scheduled maintenance window for legacy systems and develop a phased decommissioning roadmap.